Artifact Appendix: From Payload to Plugin: Web-Scale Ecosystem Attribution of JavaScript Injection Campaigns

Ravindu De Silva
ldesilva@ucsb.edu
University of California Santa Barbara, Santa Barbara, USA

Nicholas Shao
nicholasshao@ucsb.edu
University of California Santa Barbara, Santa Barbara, USA

Yigitcan Kaya
yigitcan@ucsb.edu
University of California Santa Barbara, Santa Barbara, USA

Mingxuan Yao
mingxuanyao@gatech.edu
Georgia Institute of Technology, Atlanta, USA

Yanick Fratantonio
yanickf@google.com
Google, Zurich, Switzerland

Luca Invernizzi
invernizzi@google.com
Google, Zurich, Switzerland

Christopher Kruegel
chris@ucsb.edu
University of California Santa Barbara, Santa Barbara, USA

Giovanni Vigna
vigna@ucsb.edu
University of California Santa Barbara, Santa Barbara, USA

A Artifact Appendix

A.1 Abstract

The artifact provides the source code, campaign metadata, and plotting scripts for our study of JavaScript injection campaigns across WordPress sites. It supports offline inspection of 20 campaigns observed over 84 days and regeneration of selected figures. The study also led to the disclosure of CVE-2026-6287 and the publication of indicators of compromise through AlienVault OTX. The release uses the CC BY 4.0 license included in `LICENSE`.

A.2 Description & Requirements

The root `README.md` describes the artifact. Source code is in `code/`, campaign metadata and analysis snapshots are in `data/`, and execution instructions are in `docs/run_experiments.md`.

A.2.1 Security, privacy, and ethical concerns. This evaluation follows the ethical considerations in Section B of the paper. The offline workflow reads bundled metadata and does not execute malicious JavaScript. Malicious payloads, victim domain lists, and raw crawl data are withheld as described in the README. Full similarity evaluation requires malware source code to construct abstract syntax trees (ASTs), so this workflow does not reproduce that analysis. Table 3 reports the similarity scores computed in the original study.

A.2.2 How to access. The artifact is available on Zenodo at https://zenodo.org/records/23481878. Please select version 4. The source repository is available at https://github.com/ucsb-seclab/From-Payload-to-Plugin.

A.2.3 Hardware dependencies. The offline workflow runs on a standard workstation without a GPU. Repeating data collection requires storage and compute resources appropriate to the crawl size.

A.2.4 Software dependencies. Offline evaluation requires Python 3.10 or newer and the packages in `code/requirements.txt`. The crawling system additionally requires Docker, Docker Compose, Redis, SQLite, and Chromium. Its setup is documented in `code/crawling/README.md`.

A.2.5 Benchmarks. The study data under `data/` include campaign metadata, component baselines, and saved analysis results. Full data collection and analysis require the withheld crawl corpus, payloads, and behavioral traces.

A.3 Set Up

A.3.1 Installation. Clone or download the repository and run the following commands from its root directory.

```
python3 -m venv .venv
. .venv/bin/activate
python -m pip install -r code/requirements.txt
```

A.3.2 Basic test. Run the campaign summary script from the repository root.

```
python code/evaluation/extract_campaign_stats.py
```

Successful execution prints rows for the 20 campaigns, aggregate counts, and a summary of behavioral families.

A.4 Evaluation Workflow

A.4.1 Major claims.

- (C1) The study identifies 20 campaigns and records their associated components and CVEs. Experiment E1 inspects the corresponding campaign metadata.
- (C2) The paper reports campaign detection timelines and the distribution of associated vulnerability types. Experiment E2 regenerates these visualizations from the bundled inputs.
- (C3) The study uncovered previously unreported vulnerabilities, including CVE-2026-6287, and released indicators of compromise through AlienVault OTX. Experiment E3 inspects these public disclosure records.

A.4.2 Experiments.

- (E1) Allow approximately five minutes for inspection. After installation, run the basic test and compare its campaign rows with the paper's campaign summary table and `data/`

`campaigns/`. No network access is required after dependency installation.

(E2) Allow approximately five minutes for execution and visual comparison. From the repository root, run the following commands.

```
python code/figures/fig_detection_gap.py
python code/figures/fig_vuln_heatmap.py
```

Each script writes PDF and PNG files to the current directory. Compare them with the corresponding figures in `data/figures/`. The detection timeline uses the dates recorded in the plotting script and does not query VirusTotal.

(E3) Allow approximately five minutes to compare the CVE record and OTX publications linked in C3 with the paper's disclosure findings. This inspection requires Internet access and involves no malware execution.

Tier 1 runs the campaign summary and figure scripts using bundled data. Tier 2 covers data collection and analysis that require the original crawl corpus, payloads, and behavioral traces. These inputs are withheld to protect affected sites and avoid redistributing malware. The root `README.md` explains the release policy, and `docs/run_experiments.md` describes both tiers and their execution requirements.

A.5 Notes on Reusability

The crawling, tracing, heuristic, clustering, and enrichment modules can be adapted to new authorized datasets. The README files and `docs/run_experiments.md` describe their inputs and execution requirements.

A.6 Version

Please check version 4 of the artifact through https://zenodo.org/records/23481878. The source repository is available at https://github.com/ucsb-seclab/From-Payload-to-Plugin.